ERRONKA 2 / HACKING ETIKOA

PENTESTING TXOSTEN TEKNIKOA

TryHackMe - Internal makina birtualaren segurtasun-azterketa

ATALA	INFORMAZIOA
Plataforma	TryHackMe - Internal (laborategi kontrolatua)
Helburuko IPa	**10.113.172.159**
Domeinua	internal.thm
Sistema	Ubuntu Linux 18.04 (SSH atzamar-markaren arabera)
Proben jatorrizko data	2026ko urriaren 30a
Txostenaren eguneratzea	2026ko azaroaren 3a
Tresnak	Nmap 7.98, Gobuster 3.6, WPScan 3.8.28, Metasploit 6.5.6-dev
Errubrikako atalak	HE1 · HE3 · HE4 · HE5

Txostenaren irakurketa-araua
Egiaztatuta eta **frogatzeke** dauden jarduerak berariaz bereizi dira. Ez da SSH sarbiderik, root pribilegiorik edo banderarik lortu dela baieztatzen, jatorrizko ebidentziek ez baitute hori erakusten.

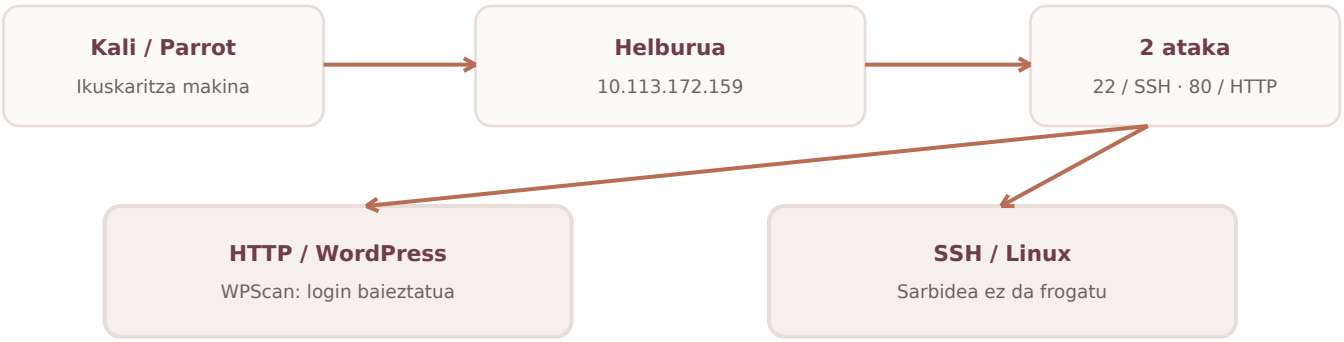
Bertsioa: 2.0 | Jatorrizko 8 orrialdeko txostenaren bertsio osatua

Hizkuntza: euskara · Helburua: ebidentziak eta ebaluazio-irizpideak argi dokumentatzea

0. Laburpen exekutiboa

TryHackMe plataformako **Internal** makina aztertu da kanpoko ikuspegitik, Kali/Parrot Linux ingurune batetik. Lehenengo helburua sareko zerbitzuak identifikatzea izan da; ondoren web-aplikazioaren eta SSH zerbitzuaren esposizioa aztertu da. Lanaren helburu operatibo osoa bi fitxategi berreskuratzea zen: **user.txt** eta **root.txt**.

ADIERAZLEA	EMAITZA
Aurkitu diren TCP ataka irekiak	**2** (22/SSH eta 80/HTTP)
Identifikatutako web teknologia	Apache 2.4.29; WordPress 5.4.2 *(eskanearen arabera)*
Baieztatutako pasahitz-proba	**1** (WordPress XML-RPC erabiliz; WPScan SUCCESS)
SSH saio arrakastatsuak	**0 egiaztatuta** - ez dago sarbide-ebidentziarik
Eskalatze arrakastatsua	**0 egiaztatuta** - ez dago proba-erregistrorik
Dokumentatutako banderak	**0** - ez da user.txt/root.txt baliorik eman



Oharra: fluxu hau ez da kompromiso oso baten froga.

Aurkikuntza garrantzitsuena WordPress kontu baten autentifikazio ahula da: WPScan tresnak **admin / my2boys** konbinazioa baliozkotzat erakutsi du. Hala ere, kontu horren administratzaile-rola, SSHrako baliozkotasuna eta Linux sisteman sarbide bat lortu izana **ez daude frogatuta**.

> **Ondorio nagusia**
> Errekonozimendua, web-enumerazioa, pasahitz-proba eta SSH fingerprintinga dokumentatuta daude. Sistema komprometitzeari eta datuetara sartzeko atal praktikoari dagozkion probak amaitu gabe daude.

1. Helburua, justifikazioa eta esparrua

1.1 Helburuak

- Helburuan ikusgai dauden TCP atakak eta zerbitzuen bertsioak aurkitzea.
- Web-aplikazioaren direktorioak, erabiltzaileak eta autentifikazio-metodoak aztertzea.
- Ahuleziak identifikatzea, larritasunaren arabera sailkatzea eta haien eragina azaltzea.
- Pasahitz-eraso kontrolatu baten emaitzak modu errepikagarrian jasotzea.

- Aukera egonez gero, baimendutako laborategian sistemarako sarbidea, pribilegioen eskalada eta banderen irakurketa frogatzea.

1.2 Esparru eta muga teknikoak

Azterketa **10.113.172.159** helburura eta **internal.thm** domeinura mugatzen da. Erregistroetan jasotako probak TryHackMe-ren laborategiko makinaren gainekoak dira; ez da hirugarrenen zerbitzurik, ekoizpen-ingurunerik edo helburutik kanpoko hostik aztertu. IPa laborategiko saioaren arabera alda daiteke; horregatik, errepikapen berri batean helburu aktiboa egiaztatu behar da.

1.3 Dokumentuen oinarriak

Txosten hau erabiltzaileak aurkeztutako *Pentesting_Internal_SSH_Actualizado(1).pdf* agirian dauden terminal-irteera transkribatuetan oinarritzen da, eta *Errubrika_Ziber_E2_26-27_T1* errubrikako HE1, HE3, HE4 eta HE5 ataletan eskatutakoa antolatzen du. Ez du jatorrizko pantaila-argazkirik, sarbide-saio berririk edo froga berri independenterik gehitzen.

> **Fidagarritasuna**
> "Egiaztatuta" etiketak jatorrizko agirian jasotako komando eta emaitzak adierazten ditu; ez du esan nahi azterketa hau egiteko unean laborategia berriz konektatu edo eskaneratu denik.

2. Auditoriaren plangintza eta ardurak (HE1)

Errubrikak auditoretzaren faseak eta arduradunak zehaztea eskatzen du. Jatorrizko txostenean metodologia orokorra badago; ondoko taulak, berriz, lanaren **plangintza dokumentala eta trazabilitatea** ematen ditu. Plangintza hau atzera begira berreraiki da, ez da aurretik onetsitako plan gisa aurkezten.

FASEA	HELBURUA / EMAITZA ESPEROA	EGOERA
01. Esparrua	Helburua, baimendutako probak eta ebidentzien gordetzea zehaztu.	Dokumentatua
02. Errekonozimendua	Sareko atakak eta bertsioak identifikatu Nmap bidez.	Eginda
03. Web enumerazioa	Gobuster bidez web-bideak eta WPScan bidez erabiltzaileak bilatu.	Eginda
04. Autentifikazio-probak	WPScan bidez hiztegi-proba mugatua egin; emaitza gorde.	Eginda (WordPress)
05. SSH analisia	Metasploit ssh_version bidez bertsioa eta algoritmoak jaso.	Eginda
06. Sistemarako sarbidea	Autentifikazio edo beste sarbide bidez shell arrakastatsua frogatu.	Frogatzeke
07. Pribilegio-eskalada	Tokiko baimenak aztertu eta root lortzea dokumentatu.	Frogatzeke
08. Ebidentziak eta itxiera	Arriskuak ordenatu, konponbideak eta mugak dokumentatu.	Osatuta / zati praktikoa pendiente

2.1 Eginkizun eta erantzukizunak

ROLA	ERANTZUKIZUNA	OHARRA
Ikasle auditorea	Proben exekuzioa, komandoen erregistroa eta pantaila-argazkiak.	Pertsonaren izena ez da zehaztu.
Txostenaren egilea	Aurkikuntzen azalpena, arrisku-balorazioa eta ondorioak.	Ebidentzien eta interpretazioen bereizketa.
Irakaslea / ebaluatzailea	Errubrikaren araberako berrikuspena eta laborategiko arauen kontrola.	Ez da aldez aurreko baliozkotzerik frogatzen.

2.2 Froga-bilketa eta errepikagarritasuna

Saio bakoitzerako data/ordua, helburuko IPa, komando zehatza, tresna-bertsioa, terminaleko irteera eta pantaila-argazkia gordetzea proposatzen da. Fitxategien izendapen bateratua: **E01_nmap_portuak.png**, **E02_nmap_bertsioak.png**, **E05_wpscan_success.png** eta antzekoak. Ez da horrelako irudirik erantsi jatorrizko materialean.

3. Metodologia eta eraso-bektoreen sailkapena (HE1)

Proba ordena hau jarraitu da: **ataken eskaneatzea → web-ibilbideen identifikazioa → WordPress-en enumerazioa → pasahitz-proba → SSH zerbitzuaren azterketa**. Azken faseak (sisteman sartzea, eskalatzea eta banderak lortzea) ez dira jatorrizko ebidentziekin egiaztatzen.

ERASO / ANALISI MOTA	ZERTARAKO	ERABILITAKO FROGA
Ataka eta zerbitzuen enumerazioa	Eraso-azalera eta teknologiak identifikatu.	Nmap -p-, -sC eta -sV
Web direktorioen enumerazioa	Ezkutuko edo administrazio-ibilbideak aurkitu.	Gobuster /blog, /phpmyadmin ...
Erabiltzaile-enumerazioa	Autentifikazio-sistemako kontuak identifikatu.	WPScan -e u → admin
Hiztegi bidezko pasahitz-proba	Kontuaren pasahitz ahula egiaztatu.	WPScan -P rockyou.txt → SUCCESS
Zerbitzuaren fingerprintinga	SSH bertsioa, host key eta algoritmoak eskuratu.	Metasploit ssh_version
Pribilegioen eskalada	Sistema barrutik baimen handiagoak lortu.	Ez da probatutako emaitzarik
Datuetara sartzea	Baimendutako lab-eko user/root banderak irakurri.	Ez da probatutako emaitzarik

3.1 Froga baten interpretazio zuzena

- **Ataka irekia:** konektagarritasunari buruzko emaitza da; ez da ustiapen-arrakasta.

- **Direktorioa aurkitua:** baliabide edo birbideraketa baten existentzia erakusten du; ez du baimenak gainditu direla esan nahi.
- **Pasahitz egokia:** kontu zehatz baten autentifikazio-proba frogatzen du, ez automatikoki beste zerbitzu baten sarbidea.
- **Fingerprintinga:** software edo algoritmo bati buruzko datua da; CVE edo exploit baten baliagarritasuna aparte aztertu behar da.

4. Sarearen eta zerbitzuen identifikazioa (HE3)

2026-10-30eko 09:18an egindako Nmap eskanearen arabera, bi TCP ataka irekita agertu ziren. 09:28ko bigarren eskanak zerbitzuen bertsioak jaso zituen.

```
nmap -p- --open -T4 -v -Pn -oN portscan 10.113.172.159
nmap -p 22,80 -sC -sV -oN servicesScan 10.113.172.159
```

ATAKA	ZERBITZUA	JASOTAKO IDENTIFIKAZIOA
22/tcp	SSH	OpenSSH 7.6p1 Ubuntu 4ubuntu0.3
80/tcp	HTTP	Apache httpd 2.4.29 (Ubuntu)

SSH bertsioaren atzamar-markak Ubuntu Linux 18.04 erakusten du. Bertsio kate horiek ez dute sistema eragilearen patch-egoera zehatza, softwarearen ustiagarritasuna edo sarbide-arrakasta bermatzen.

4.1 Errepikatzeko baldintzak

Eskaneoa errepikatzeko, VPN bidez TryHackMe laborategira konektatuta egon behar da, egungo helburuko IPa baieztatu eta **portscan** nahiz **servicesScan** fitxategiak gorde. Hori egitean pantaila-argazkiak eta erregistro osoak erantsi behar dira.

> **Ebidentzia bisuala falta da**
> E01 eta E02 emaitzak txostenean testu gisa daude; ez dira terminaleko jatorrizko pantaila-argazkiak jaso. HE3ko kalifikaziorik altuena lortzeko irudiak gehitzea komeni da.

5. Web direktorioen enumerazioa (HE3)

Apache zerbitzua identifikatu ondoren, Gobuster bidez HTTP bide interesgarriak enumeratu ziren. Gunearen erroan Apache-ren ohiko *It works* orria agertu zen.

```
gobuster dir -u http://10.113.172.159 \
  -w /usr/share/wordlists/dirb/common.txt
```

BIDEA	HTTP	INTERPRETAZIOA
/blog/	301	Birbideraketa. WordPress instalazioa ondoren aztertu da.
/wordpress/	301	Aurkitutako beste ibilbide bat; erabilgarritasuna ez da baliozkotu.

BIDEA	HTTP	INTERPRETAZIOA
/phpmyadmin/	301	Administrazio-ibilbidea detektatua; ez dago baimenik gabeko sarbidearen frogarik.
/javascript/	301	Web-baliabideetara birbideraketa.
/index.html	200	Apache-ren web orri publikoa erantzuten du.
/.hta, /.htaccess, /.htpasswd	403	Sarbidea ukatua.
/server-status	403	Sarbidea ukatua.

Kodeen esanahia: 200 = baliabidea eskuragarri; 301 = birbideraketa; 403 = sarbidea ukatua. Aurkitutako bideek azalera aztertzeko balio dute, baina ez dira denak segurtasun-ahulezia frogatuak.

5.1 Domeinurako sarbidea

Hasierako WPScan saiakera batean **Couldn't resolve host name** errorea dokumentatu zen. Ondoren, **internal.thm → 10.113.172.159** lotura agertu zen terminaleko emaitzetan. Ez da zehazki dokumentatu zer DNS edo hosts aldaketa egin zen; beraz, aldaketa jakin bat egindakotzat ez da aurkeztu.

6. WordPress-en azterketa eta pasahitz-proba (HE3 / HE4)

Web-enumerazioan aurkitutako **/blog/** bidean WordPress instalazioa identifikatu zen. WPScan bidez erabiltzaileak, bertsioa eta bestelako konfigurazio-zantzuak aztertu ziren.

```
wpscan --url http://internal.thm/blog/ -e u
```

ELEMENTUA	EMAITZA
WordPress	5.4.2; WPScan-ek zaharkitua dela markatu du.
Gaia	Twenty Seventeen 2.3 (%80ko konfiantza).
XML-RPC	/blog/xmlrpc.php helbidean aktiboa dirudi.
Erabiltzailea	admin; egileak, RSS, API eta login-mezuak erabili dira.
Pluginak	Ez da pluginik aurkitu erabilitako detekzio-metodoekin.
Konfigurazioen backupak	Ez da backuprik aurkitu egindako bilaketan.

6.1 Hiztegi bidezko autentifikazio-proba

Laborategian **rockyou.txt** hitz-zerrenda erabili zen **admin** erabiltzailearen pasahitza egiaztatzeko. WPScan-en XML-RPC bidezko probaren emaitza honela dago jasota:

```
wpscan --url http://internal.thm/blog/ \
  -U admin -P /usr/share/wordlists/rockyou.txt
[+] Performing password attack on Xmlrpc against 1 user/s
[SUCCESS] - admin / my2boys
[!] Valid Combinations Found: admin / my2boys
```

Emaitza egiaztatua
Jatorrizko txostenean **admin / my2boys** WordPress konturako baliozko konbinazioa gisa agertzen da. Ez dago kontu horren rol zehatzaren, panelera sartzeko saio baten edo SSH autentifikazioaren froga zuzena.

6.2 Arriskuaren interpretazioa

Hiztegi publiko batean aurkitutako pasahitza erabiltzeak kontuaren aurkako hiztegi-erasoen arriskua handitzen du. Eragina kontu horren benetako baimenen araberakoa da; erabiltzailearen izena **admin** izateak ez du berez WordPress administrazio-rola frogatzen. XML-RPC zerbitzua aktibo egoteak autentifikazio-saiakera alternatiboak ahalbidetu ditzake, baina hori bakarrik ez da RCE baten froga.

7. Metasploit eta SSH zerbitzuaren analisia (HE3)

7.1 Baztertutako moduluaren azalpena

Hasieran **exploit/linux/http/ivanti_connect_secure_rce_cve_2024_37404** modulua aztertu zen. Modulu hori Ivanti Connect Secure produktuaren ahulezia bati dagokio, baina helburuan Apache, OpenSSH eta WordPress identifikatu dira; ez dago Ivanti produktuaren ebidentziarik. Horregatik ez da modulu hori helbururako egokitzat hartu eta ez da arrakastarik aldarrikatzen.

```
use exploit/linux/http/ivanti_connect_secure_rce_cve_2024_37404
info
```

7.2 SSH bertsioaren azterketa zuzena

```
use auxiliary/scanner/ssh/ssh_version
set RHOSTS 10.113.172.159
set RPORT 22
run
```

EREMUA	EMAITZA
SSH banner	SSH-2.0-OpenSSH_7.6p1 Ubuntu-4ubuntu0.3
Sistema	Ubuntu Linux 18.04 (fingerprinting).
Host-key motak	RSA, ECDSA eta ED25519 (Nmap).
ED25519 fingerprinta	b0:7f:7f:7b:52:62:62:2a:60:d4:3d:36:fa:89:ee:ff
Zifratzea	chacha20-poly1305; aes-ctr; aes-gcm familietako aukerak.
HMAC	hmac-sha2-256, hmac-sha2-512-etm, hmac-sha1.

EREMUA	EMAITZA
Gako-trukea	curve25519, ecdh-sha2-nistp256, diffie-hellman-group14-sha1.
Konpresioa	none; zlib@openssh.com.

7.3 Aurkikuntzen esanahia

Metasploit-ek **Weak elliptic curve** ohartarazpena agertu zuen **ecdsa-sha2-nistp256** algoritmoaren testuinguruan. Tresnaren ohartarazpen hori berrikusteko pista da, ez gakoen hausturaren edo SSH ustiapen arrakastatsuaren froga. SHA-1 duten aukerak agertzeak konfigurazio-politika eguneratzeko beharra aztertzea justifikatzen du, baina arrisku zehatza ez da baliozkotu.

> **Zer ez du egin ssh_version moduluak?**
> Ez du kontu baten pasahitza erakusten, ez du SSH saio bat irekitzen eta ez du root sarbidea bermatzen. **Auxiliary module execution completed** mezuak modulua amaitu dela baino ez du adierazten.

8. Ahulezien erregistroa eta lehentasunak (HE3)

Honako balorazioa **kualitatiboa** da, eta jatorrizko emaitzen gainean egindako interpretazioa. Ez da CVSS kalkulu formal bat, ez baita kasu guztietan eragina, esplotagarritasuna eta konfigurazioa egiaztatu. Ahulezia baieztatuak, zantzuak eta informazio-aurkikuntzak nahastu gabe aurkezten dira.

ID	AURKIKUNTZA	EGOERA	LARRITASUNA
A1	WordPress kontuaren pasahitz ahula	Baieztatua	**Handia**
A2	WordPress 5.4.2 bertsio zaharkitua	Bertsioa baieztatua; CVE zehatzik ez	Ertaina*
A3	XML-RPC interfazea erabilgarri	Detektatua; erabilera frogatua	Testuinguruaren araberakoa
A4	/phpmyadmin/ bidea ikusgai	Bidea baieztatua; sarbiderik ez	Informatiboa
A5	Apache/OpenSSH bertsioei buruzko informazioa	Bertsioak baieztatuta	Informatiboa
A6	SSH konfigurazioko algoritmoak berrikusteko	Zerrendak eta ohartarazpena	Baxua*
A7	SSH egiaztapenaren egoera	Login emaitzarik ez	Ez da ahulezia frogatua

* Arrisku-balorazio behin-behinekoa; konfigurazioa eta ondorio errealak egiaztatu gabe daude.

A1 · WordPress pasahitz ahula

Egoera / larritasuna: Handia - baieztatuta
Froga: WPScan [SUCCESS] - admin / my2boys. Hiztegi-proba XML-RPC bidez.
Eragin posiblea: Kontu horren baimenetara sarbide ez-baimendua ahalbidetu dezake; benetako eskumenak ez daude egiaztatuta.
Gomendioa: Kontuaren pasahitza berehala aldatu, pasahitz bakarra erabili, MFA egokia ezarri eta saiakera hutsak mugatu/monitorizatu.

A2 · WordPress bertsio zaharkitua

Egoera / larritasuna: Ertaina - aurrebalorazioa
Froga: WPScan: WordPress 5.4.2.
Eragin posiblea: Mantentze-egoerak ezagututako ahulezien esposizioa handitu lezake; CVE ustiatu bat ez da frogatu.
Gomendioa: WordPress core eta gaia bateragarri den bertsio eguneratu batera pasa; eguneraketa ondoren funtzioak probatu.

A3 · XML-RPC aktiboa

Egoera / larritasuna: Konfigurazioaren araberakoa
Froga: /blog/xmlrpc.php; WPScan hiztegi-probaren kanal gisa erabili da.
Eragin posiblea: Autentifikazio-azalera handitu dezake. Aktibo egotea bakarrik ez da ahulezia.
Gomendioa: Beharrezkoa den erabaki; beharrezkoa ez bada desgaitu, eta bestela autentifikazio-mugak eta monitorizazioa jarri.

A4 · phpMyAdmin ibilbidea aurkitua

Egoera / larritasuna: Informatiboa
Froga: Gobuster: /phpmyadmin/ → HTTP 301.
Eragin posiblea: Administrazio-interfaze posible bat agerian uzten du; ez dago bertara sartzeko frogarik.
Gomendioa: Administrazio-panelen sarbidea barne-sare/VPN edo IP zerrenda baimenduetara mugatu.

A5 · Zerbitzu-bertsioen identifikazioa

Egoera / larritasuna: Informatiboa
Froga: Nmap: Apache 2.4.29, OpenSSH 7.6p1 Ubuntu 4ubuntu0.3.
Eragin posiblea: Bertsio-informazioak azterketa zuzentzen du, baina ez du berez ustiagarritasuna frogatzen.
Gomendioa: Eguneraketa eta segurtasun-adabakiak mantendu; zerbitzuen konfigurazioa gainbegiratu.

A6 · SSH algoritmoen konfigurazioa

Egoera / larritasuna: Baxua - aurrebalorazioa
Froga: hmac-sha1 eta diffie-hellman-group14-sha1 zerrendak; Weak elliptic curve ohartarazpena.
Eragin posiblea: Kriptografia-politika zaharrak onartzeko arrisku posiblea; ez da kompromisorik frogatu.
Gomendioa: SSH hardening politika eguneratu; algoritmo zaharrak bateragarritasunaren eta beharren arabera kendu.

9. Pasahitz-erasoaren dokumentazio zehatza (HE4)

Errubrikako HE4 atalak pasahitz-erasoa nola prestatu eta nola gauzatu den deskribatzea baloratzen du. Dokumentatutako proba **WordPress-eko admin** erabiltzailearen aurkakoa da, **rockyou.txt** hiztegia erabilita.

URRATSA	EKINTZA	EMAITZA / FROGA
1	Web-instalazioa identifikatu	/blog/ WordPress instalazioa.
2	Erabiltzailea enumeratu	WPScan -e u → admin.
3	Hiztegia hautatu	/usr/share/wordlists/rockyou.txt.
4	Autentifikazio-proba egin	WPScan -U admin -P ...; XML-RPC bidea.

URRATSA	EKINTZA	EMAITZA / FROGA
5	Emaitza baliozkotu	[SUCCESS] admin / my2boys.
6	Mugak idatzi	Ez dago SSH loginaren edo WordPress rolaren frogapenik.

Proba honen errepikagarritasunerako funtsezkoak dira helburuko URLa, erabiltzaile-izena, hiztegiaren kokapena, komandoa eta [SUCCESS] lerroa. Erregistroan ez dira probako saiakera-kopuru osoa, iraupena edo abiadura jaso; ondorioz, datu horiek ez dira asmatu.

> **Kontu eta zerbitzuen bereizketa**
> WordPress-en pasahitz-proba arrakastatsua ezin da SSHrako pasahitz zuzena dela ondorioztatzeko erabili. Kontu baten izena beste zerbitzu batean existitzen denik ere ez da frogatzen.

10. Sistemarako sarbidea, eskalada eta datuak (HE5)

HE5 atalak pribilegioen eskalada eta baimendutako laborategiko datuetara sartzea **benetan lortu eta dokumentatzea** eskatzen du. Jatorrizko PDFan ez dago shell saio arrakastatsuaren, **user.txt**-ren edo **root.txt**-ren frogarik. Horregatik, atal hau osatutako **prozedura eta egiaztapen-plana** da, ez egindako exekuzioaren emaitza.

EKINTZA	KOMANDOA / EGIAZTAPENA	EGOERA
WordPress sarbidea	/blog/wp-login.php bidez saioa probatu eta rola egiaztatu.	Frogatzeke
SSH sarbidea	ssh ERABILTZAILEA@10.113.172.159, egiaztatutako kontuarekin soilik.	Frogatzeke
Hasierako shell froga	whoami, id, hostname; terminalaren irudia gorde.	Frogatzeke
Tokiko baimenak	sudo -l; egiaztatutako zerbitzu eta exekuzioen berrikuspena.	Frogatzeke
User bandera	user.txt kokatu eta irakurketa frogatu.	Frogatzeke
Root eskalada	Aurkitutako mekanismo egokiaren exekuzioa eta id-ren emaitza.	Frogatzeke
Root bandera	root.txt kokatu eta irakurketa frogatu.	Frogatzeke

10.1 Froga lokalak - sarbidea lortuz gero bakarrik

```
whoami
id
hostname
sudo -l
```

Komando horiek saio baimendu baten barruan exekutatzeko proposatu dira. **Ez dago** aurkeztutako erregistroetan exekuzio horien emaitzarik. Pribilegioen eskalada egiteko ahuleziarik ere ez da identifikatu dokumentatutako frogen artean.

10.2 Esperotako ebidentzia-fitxak

ID	FROGA BEHARREZKOA	ZER ERAKUTSI BEHAR DU
E09	Sistemarako sarbidearen pantaila-argazkia	Erabiltzaile-identitatea, host izena eta saio mota.
E10	user.txt fitxategiaren irakurketa	Fitxategiaren kokapena eta irakurketa baimendua; balio sentikorrak behar izanez gero estalita.
E11	Pribilegioen eskaladaren irudia	Eskalada-bektorea, exekuzioa eta root baimenak id bidez.
E12	root.txt irakurketa	Root eskubideekin eskuratutako fitxategiaren froga.

HE5en gaur egungo egoera
Lan honetatik ezin dira E09-E12 pantaila-argazkiak edo bandera-balioak sortu, ez baitira jatorrizko materialetan agertzen. Atal praktikoa amaitutzat emateko laborategian probak egin eta ebidentzia errealak erantsi behar dira.

11. Ondorio teknikoak eta konponketa-plana (HE3)

Gomendioak lehentasunez banatu dira. Epe orientagarriak **proposamenak** dira, ez benetan ezarritako neurriak edo aurretik adostutako SLA bat.

EPEA	LANAK	ARRAZOIA / FROGA
Berehala / 0-7 egun	WordPress kontuaren pasahitza aldatu; pasahitz bakarrak eta MFA ezarri; XML-RPCko autentifikazio saiakerak mugatu.	A1en autentifikazio-proba arrakastatsua.
Epe laburra / 30 egun	WordPress core/gaia eguneratu; administrazio-interfazeetako sarbidea murriztu; login saiakerak monitorizatu.	A2, A3 eta A4ren eragina murriztu.
Epe ertaina / 90 egun	SSH algoritmoen konfigurazioa aztertu, eguneraketa-prozesu automatikoa eta aldizkako auditoria ezarri.	A5 eta A6ri lotutako segurtasun-hobekuntza.
Jarraipena	Aldaketak berriz probatu; emaitzak eta pantaila-argazkiak dokumentatu.	Ebidentzia errepikagarriak eta zuzenketen baliozkotzea.

11.1 Zuzenketa baliozkotzeko irizpideak

- **A1:** aurretik aurkitutako pasahitzak ez luke berriz autentifikatu behar; pasahitz-politika berria dokumentatu.
- **A2:** WPScan-en bertsio-identifikazioa berriz exekutatu eta bertsio onartua egiaztatu.
- **A3:** XML-RPC desgaitu bada, muturreko funtzioek oraindik behar bezala jarduten dutela ziurtatu.
- **A4:** phpMyAdmin sarbidea baimendutako jatorrietatik soilik dagoela aztertu.
- **A6:** SSH algoritmoen negoziazioaren emaitza berria eta konexio legitimoko bateragarritasuna egiaztatu.

12. Azken ondorioak eta azterketaren mugak

Azterketaren errekonozimendu-faseak bi TCP zerbitzu aurkitu ditu: SSH eta HTTP. Gobuster tresnak web-bide esanguratsuak identifikatu ditu, eta WPScan-ek WordPress-en bertsioa, **admin** erabiltzailea eta baliozko pasahitz-konbinazio bat eman ditu. SSH zerbitzuaren bertsioa eta zenbait algoritmo Nmap eta Metasploit bidez dokumentatu dira.

Segurtasunaren ikuspegitik, lehentasunik handiena WordPress kontuaren autentifikazio ahulak du, proba zuzen baten emaitza delako. WordPress bertsioaren egoera, XML-RPC interfazea, phpMyAdmin bidea eta SSH konfigurazioa egiaztapen gehigarriak egiteko arrazoiak dira, baina ez dira denak ustiatu diren ahuleziak.

Metodologiaren ikuspegitik, aurreko bertsioari plangintza, laneko ardurak, froga-metodoen bereizketa, arriskuen sailkapena, banakako gomendioak eta errubrikarekiko trazabilitatea gehitu zaizkio. Halere, oraindik falta dira sarbide-saioaren froga, eskalada, banderak eta jatorrizko terminaleko irudiak.

> **Txostenaren amaierako egoera**
> **HE1:** plangintza eta teknikak dokumentatuak. **HE3:** zerbitzuak, ahuleziak eta gomendioak dokumentatuak; argazkiak falta. **HE4:** WordPress pasahitz-proba frogatua. **HE5:** prozedura dokumentatua, baina emaitza praktikoak falta.

A. Eranskina - Komandoen erregistroa

Ondoko komandoak jatorrizko agirian dauden proba teknikoetatik aterata daude. Proposatutako komandoak bereizita daude.

ID	KOMANDOA / MODULUA	EGOERA
E01	nmap -p- --open -T4 -v -Pn -oN portscan 10.113.172.159	Erregistroan jasota
E02	nmap -p 22,80 -sC -sV -oN servicesScan 10.113.172.159	Erregistroan jasota
E03	gobuster dir -u http://10.113.172.159 -w /usr/share/wordlists/dirb/common.txt	Erregistroan jasota
E04	wpscan --url http://internal.thm/blog/ -e u	Erregistroan jasota
E05	wpscan --url http://internal.thm/blog/ -U admin -P /usr/share/wordlists/rockyou.txt	Erregistroan jasota
E06	exploit/linux/http/ivanti_connect_secure_rce_cve_2024_37404 (info)	Aztertua; ez egokia
E07	auxiliary/scanner/ssh/ssh_version (RHOSTS 10.113.172.159; RPORT 22; run)	Erregistroan jasota
E08	auxiliary/scanner/ssh/ssh_login (show options)	Prestatzeko proposatua
E09-E12	SSH/shell, user.txt, root eskalada eta root.txt froga	Egiteke

A.1 Kredentzialen eta gakoen erregistroa

WordPress: **admin / my2boys** konbinazioa WPScan-ek baliozkotzat erakutsi du. SSH ED25519 fingerprinta: **b0:7f:7f:7b:52:62:62:2a:60:d4:3d:36:fa:89:ee:ff**. Ez dago beste kontu edo pasahitzik baliozkotuta.

B. Eranskina - Errubrikaren trazabilitatea

ERRUBRIKA	ESKATUTAKOA	TXOSTENEKO ATALA	EBIDENTZIA
HE1 (2,5 %)	Auditoretza planifikatzea	1-3	Faseen eta arduradunen taula; berreraikitako plangintza.
HE1 (5 %)	Ahuleziak eta eraso motak	3-8	Nmap, Gobuster, WPScan, SSH, kategoriak.
HE3 (1,5 %)	Zerbitzuak identifikatzea	4-7	22/SSH, 80/HTTP eta bertsioak; irudiak falta.
HE3 (4 %)	Ahuleziak dokumentatzea	8	A1-A7 erregistro sailkatua.
HE3 (2 %)	Informazioa osatzea	3-8 eta A	Komandoak, metodoa eta frogaren muga.
HE3 (5 %)	Ondorioak eta gomendioak	11-12	Larritasuna, eragina, konponketa-epeak.
HE4 (7,5 %)	Pasahitzen erasoa	6 eta 9	WPScan SUCCESS eta rockyou.txt.
HE5 (4,5 %)	Pribilegioen eskalada	10	Falta; prozedura soilik.
HE5 (4,5 %)	Baimendu gabeko datuetara sarbidea	10	Falta; user.txt eta root.txt frogatzeke.

B.1 Hurrengo saioan erantsi beharreko irudiak

- E01: Nmap ataken eskaneoko irteera, IPa eta 22/80 portuak ikusgai.
- E02: Nmap -sC -sV emaitza, Apache/OpenSSH bertsioak ikusgai.
- E03: Gobuster terminala, direktorioak eta HTTP kodeak ikusgai.
- E05: WPScan [SUCCESS] emaitza, pasahitza behar izanez gero estalita.
- E07: ssh_version modulua eta jasotako banner/algoritmoak.
- E09-E12: konpromiso-saioa, erabiltzailea, eskalada eta bi banderak, lortzen badira.

> **Ezinbesteko ohartzea**
> Argazki horiek ez dira dokumentu honetan sartu, ez direlako igorritako materialetan agertzen. Terminaleko emaitzak testu gisa transkribatu dira; ez da faltsututako pantaila-argazkirik erabili.

C. Eranskina - Ebidentzia-fitxaren eredua

Beheko eredua erabili falta diren egiaztapenak gehitzeko. Arlo bateko emaitzarik ez badago, **"Egiteke"** idatzi; ez asmatu ekintza edo emaitzarik.

EREMUA	JASO BEHARREKO DATUA
Ebidentzia IDa	E09 / E10 / E11 / E12 ...
Saioaren data eta ordua	____ / ____ / _____ ____:____
Helburua	Helburuko IP aktiboa, domeinua eta makina
Probaren helburua	Zer frogatu nahi den eta zergatik
Komando edo tresna	Exekutatutako komandoa eta bertsioa
Benetako terminal-irteera	Kopiatu den irteera, laburtu gabe beharrezkoa bada
Pantaila-argazkia	Fitxategiaren izena eta non gorde den
Emaitza	Arrakasta / Huts egin du / Ez da probatu
Ondorioa	Emaitzak zer frogatzen duen eta zer EZ duen frogatzen

C.1 Betetako adibidea: E05 (WordPress)

Proba: WPScan XML-RPC bidezko hiztegi-proba. **Erregistroko data:** 2026-10-30eko azterketa, ordu zehatzik gabe. **Helburua:** http://internal.thm/blog/. **Emaitza:** [SUCCESS] admin / my2boys. **Interpretazioa:** WordPress konturako pasahitz baliozkoa; ez du SSH saioa edo WordPress administratzaile-rola frogatzen. **Irudia:** erantsi gabe.

Jatorrizko dokumentuen erreferentziak

1. *Pentesting_Internal_SSH_Actualizado(1).pdf*, 8 orrialde, 2026-10-30. Nmap, Gobuster, WPScan eta Metasploit emaitzekin.
2. *Errubrika_Ziber_E2_26-27_T1.xlsx - Teknikoa_ERRONKA2.pdf*, 4.-5. orrialdeak bereziki: HE1, HE3, HE4, HE5; HE6 Android dokumentuan lantzekoa.